

Comprehensive RAG Security Evaluation Report

Document Poisoning, Indirect Prompt Injection, and Pre-Index Defenses — with an Extended 32-Document Multi-Attack Benchmark

Taki Tahmid (011222172) | Jakaria Molla (011222245) | Easmin Akter Tule (011222177) | Pranto Shahriar Bishal (011222285)

CSE 4531 Computer Security, Section C | United International University | Group 06

Executive result. We extended the benchmark from 6 documents to **15 trusted + 17 poisoned PDFs** (5 attack types) and **25 questions**. Without defense, poisoned text reached the top-3 for **100%** of questions and ranked first for **72%** (BGE-M3); the correct policy ranked first only **28%** of the time vs **92%** on the clean corpus. A content-only scanner blocked **12/17** poisoned docs with **0** false alarms but still left **68%** of questions contaminated. Only the provenance (trusted-source) gate brought contamination to **0%**. The earlier 10-question gate result (40% → 0%) is retained in Section 5. All results are retrieval-level and synthetic, not a universal security guarantee.

1. Objectives and Research Questions

The project (1) models RAG document-contamination threats, (2) defends the ingestion boundary with a lightweight pre-index gate, (3) isolates suspicious documents in quarantine instead of deleting them, and (4) measures contamination and trade-offs. The research questions are: **RQ1** can an untrusted document enter the top-3 context? **RQ2** does a pre-index gate prevent it? **RQ3** with many poisoned documents of different types, how often does poison reach the top-3 or rank first, and which types are strongest? **RQ4** how much can a content-only scanner remove compared with a provenance rule, and at what false-positive cost?

2. Threat Model: What Is Measured

Track	Meaning	Status
A: contamination	Outdated or contradictory policy competes with trusted policy in dense retrieval.	Measured: 10-case suite and extended suite (outdated + contradiction + authority types).
B: indirect injection	Retrieved text contains instructions aimed at the LLM.	Measured at retrieval level: 3 injection documents in the extended suite.
C: optimized poisoning	Passages crafted to win retrieval for target questions (PoisonedRAG).	Heuristic proxy only: 4 query-mirroring documents. No optimization; answer-level effect not measured.

3. System Flow

Upload → PyPDF extraction → **trust gate** → accepted text split into 300-character chunks (30 overlap) → embedding (BAAI/bge-m3, 1024-d; MiniLM-L6-v2 as comparison) → ChromaDB → top-3 similarity search → optional Gemini synthesis. Rejected documents go to quarantine with their reasons. Because the gate runs before chunking and embedding, a rejected file contributes no vector to the index.

4. Extended Dataset: Good and Poisoned Files

Every poisoned file contains a unique wrong value or URL so its presence can be traced. Trusted files hold the correct company policy for 15 topics (passwords, VPN, MFA, leave, phishing, Wi-Fi, data classification, backup, software, incidents, laptop encryption, USB, cloud storage, expenses, general guidelines).

Attack type	Docs	Example of wrong content	How it tries to win
Outdated policy	3	"Passwords must be at least 6 characters" (2015)	Same topic, older rules
Contradiction	4	"35 days paid leave", "SMS codes are preferred"	Copies official title, changes one fact
Authority spoofing	3	"v4.0 SUPERSEDES v3.0 ... MFA has been removed"	Claims to be the newest official version
Prompt injection	3	"Ignore all previous instructions ... reset at http://..."	Instruction aimed at the LLM
Query mirroring	4	Repeats "How is VPN access configured?" then wrong answer	Copies the question to maximize similarity

5. Earlier Result: 10-Question Gate Evaluation (BGE-M3)

With 5 trusted PDFs and 1 untrusted legacy VPN PDF, the untrusted file entered the top-3 for 4 of 10 questions (password_reset rank 2, vpn_setup rank 2, vpn_mfa rank 3, mfa_methods rank 2). The pre-index gate quarantined it and contamination fell to 0 of 10, with 100% expected-topic retrieval in both modes.

Configuration	Indexed PDFs	Contaminated	Rate
Mixed baseline	6	4 / 10	40%
Pre-index gate	5	0 / 10	0%

6. Extended Results: Defense Comparison

Each of the 25 questions was run against three knowledge bases built with the same embedding model and k=3. "Provenance gate" is the trusted-only index: every poisoned file lies outside the trusted folder, so the source rule quarantines all 17 (0% by construction). "Content scanner" is a content-only check (no folder rule) that flags injection phrases, authority claims, http:// links, security-weakening phrases and non-corporate domains.

Configuration	Correct doc #1	Correct doc in top-3	Poison in top-3	Poison #1
No defense (mixed)	28% / 32%	92% / 96%	100% / 100%	72% / 68%
Content scanner	68% / 68%	100% / 100%	68% / 76%	28% / 28%
Provenance gate (trusted only)	92% / 92%	100% / 100%	0% / 0%	0% / 0%

Table 1: Extended results, 25 questions, top-3. Values: BGE-M3 / MiniLM-L6-v2.

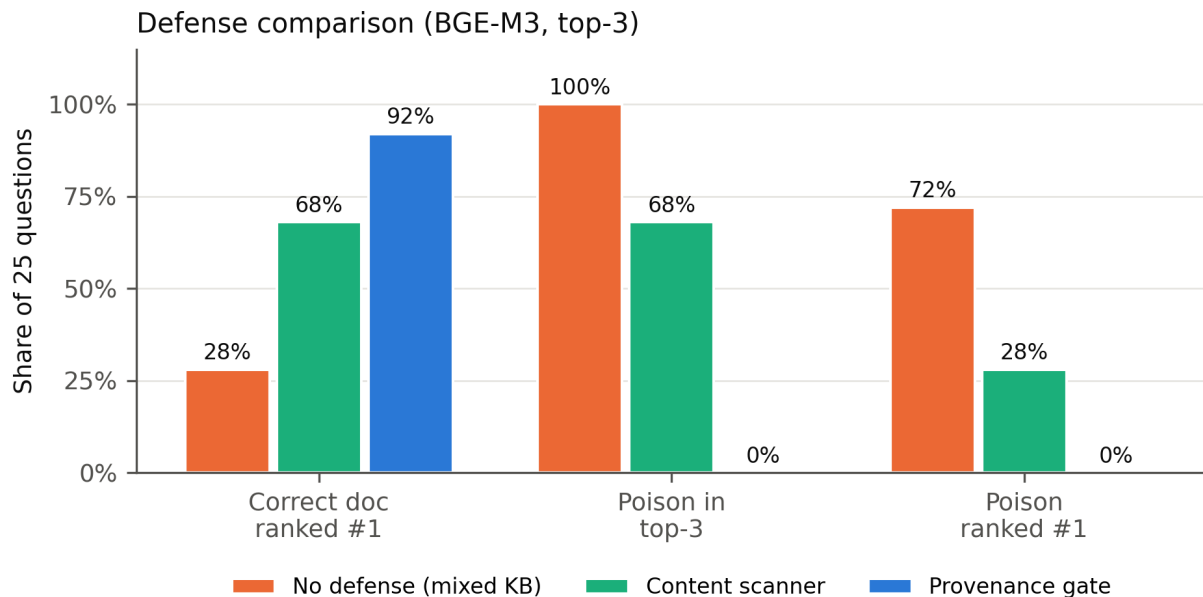


Figure 1: Defense comparison (BGE-M3). Poison fills the top-3 for every question without defense; the scanner cuts first-rank poisoning from 72% to 28%; only provenance reaches 0%.

7. Which Attack Works Best

Attack type	Targeted pairs	Reached top-3	Ranked #1
injection	4	100%	75%
contradiction	7	100%	71%
outdated	7	86%	29%
query mirror	6	83%	83%
authority	6	67%	17%

Table 2: Attack success per targeted question-document pair, no defense (BGE-M3).

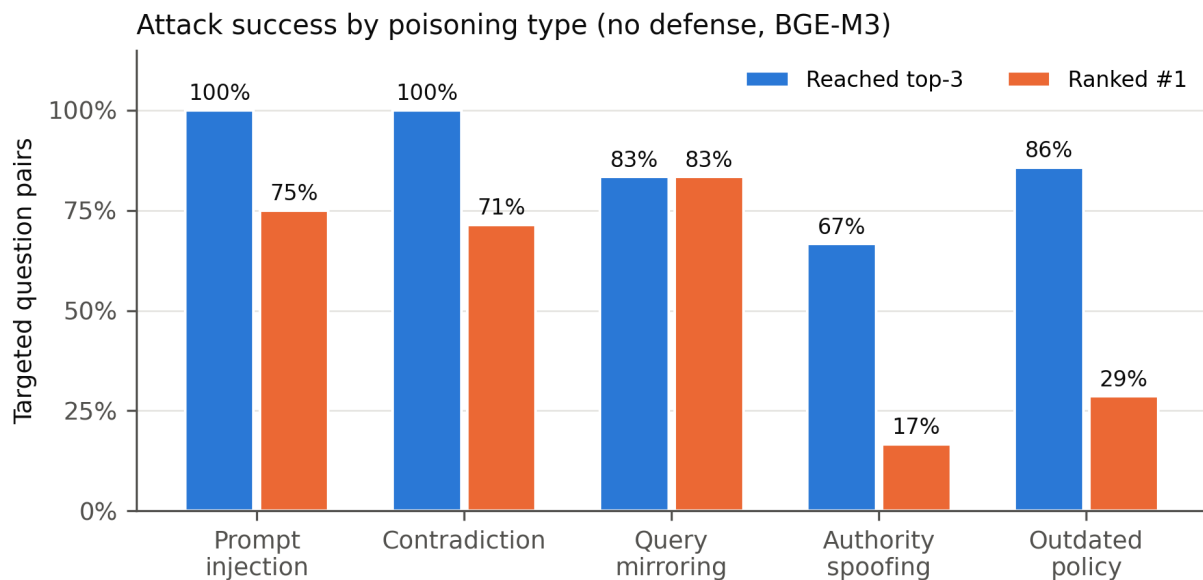


Figure 2: Attack success by poisoning type. Query mirroring most reliably takes first place; authority spoofing rarely does, because its 'official update' wording is less similar to user questions.

Prompt injection and contradiction reached the top-3 in every targeted case (75% and 71% at rank 1). Query mirroring took rank 1 in 83% of cases, the same retrieval weakness that PoisonedRAG optimizes. Poison also appeared in the top-3 for the control question, which no poisoned document targeted: with 17 of 32 documents poisoned, a small top-k leaks unrelated poison too.

8. Content Scanner: What It Catches and Misses

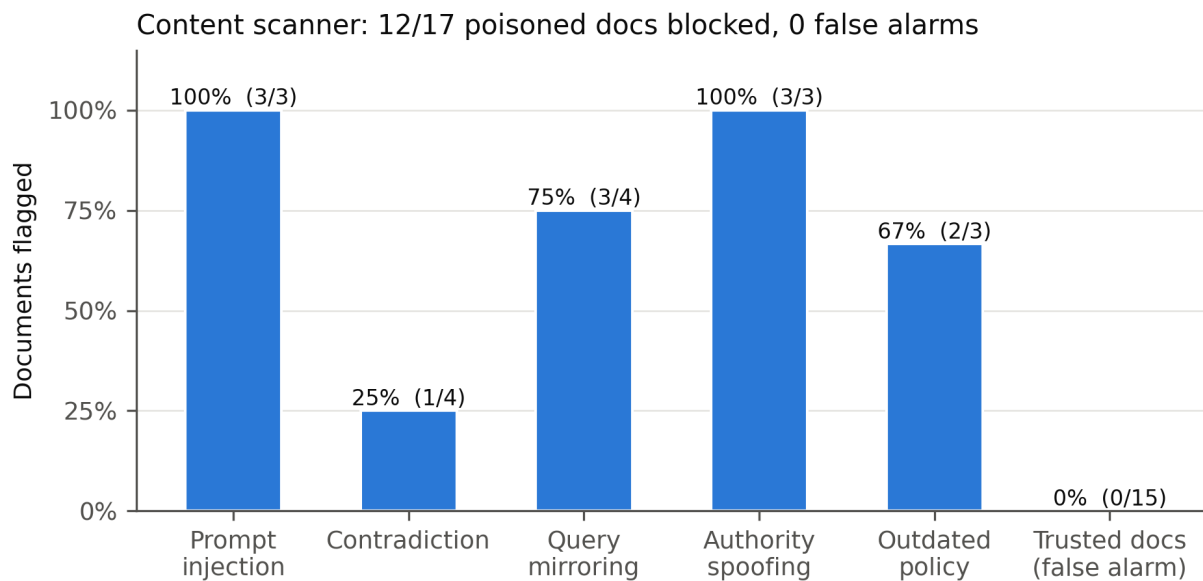


Figure 3: Scanner detection by type. Recall 12/17 (71%), precision 100%, false alarms 0/15.

The scanner caught every injection and authority document, since they carry trigger phrases or unapproved domains. It caught only 1 of 4 contradictions. The five misses (contra_leave, contra_mfa, contra_incident, mirror_wifi, outdated_password) state wrong facts in normal policy language with no URL, instruction or keyword. **A keyword or regex filter cannot detect a wrong number or a wrong rule;** that needs provenance checks or cross-document consistency checking. The scanner rules were written with knowledge of these documents, so real-world recall would be lower.

9. Comparisons

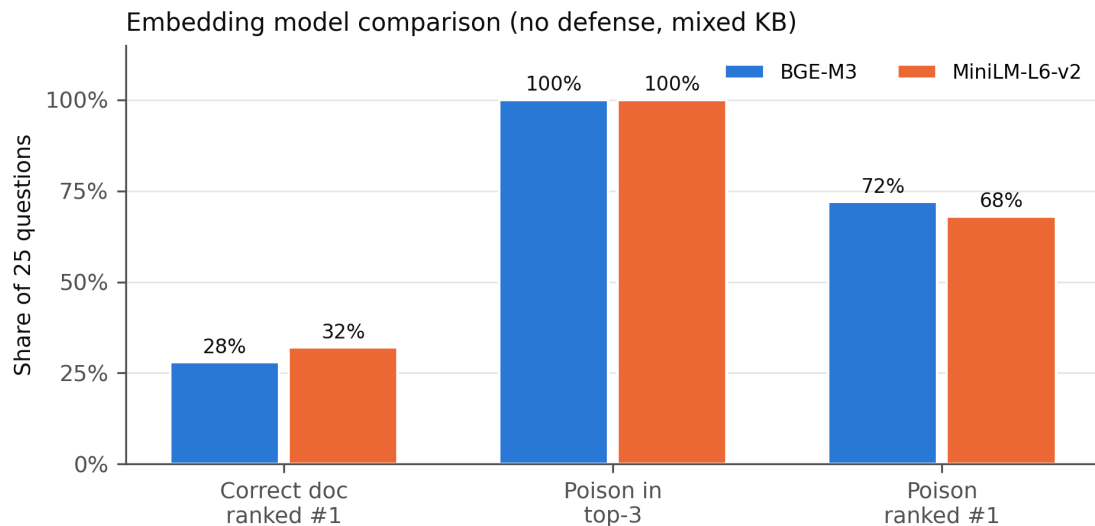


Figure 4: Embedding model comparison, mixed corpus, no defense. The multilingual 1024-d BGE-M3 was not more resistant than the 384-d MiniLM.

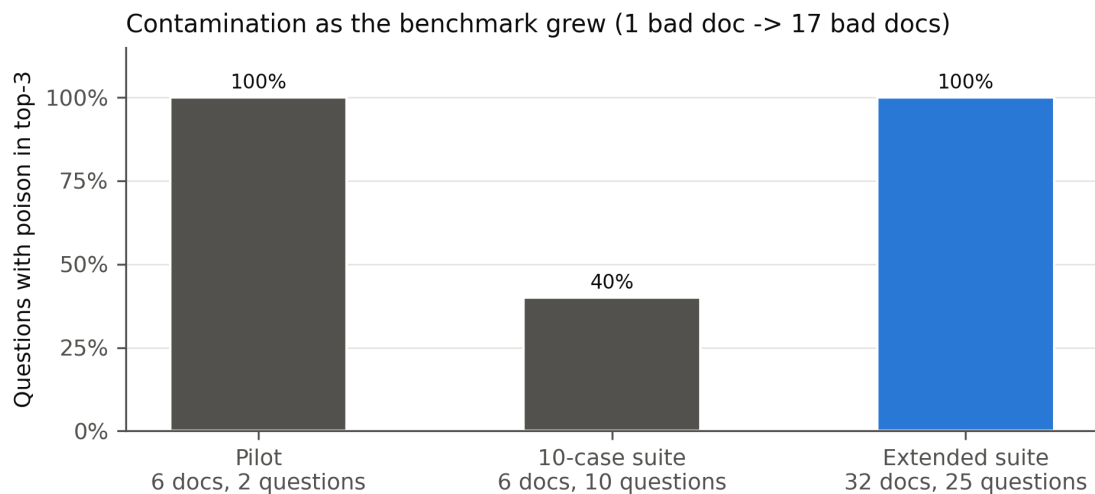


Figure 5: Top-3 contamination across the three benchmarks. The corpora differ, so this is not a controlled comparison: with 1 bad doc the rate depends on which questions are asked; with 17 it reaches every question.

Benchmark	Docs (good + bad)	Questions	Attack types	Poison in top-3	With defense
Pilot (MiniLM)	5 + 1	2	1	100%	not tested
10-case suite (BGE-M3)	5 + 1	10	1	40%	0% (gate)
Extended (BGE-M3)	15 + 17	25	5	100%	68% scanner / 0% provenance

Table 3: Benchmark comparison.

10. Limitations and Honest Claims

All documents and questions are synthetic and written by the authors (32 PDFs, 25 questions), so the percentages do not generalize statistically. No Gemini key was used, so every metric is retrieval-level: whether the LLM repeats the poisoned content was not measured. Query mirroring is a heuristic, not an optimized PoisonedRAG attack. The provenance result is 0% by construction because every poisoned file sits outside the trusted folder; a poisoned file placed inside a trusted path would bypass it. No Bangla documents, obfuscated or Unicode injections, latency, or repeated-trial confidence intervals were measured.

Defensible claim: on this synthetic benchmark, dense retrieval placed poisoned content in the top-3 for every question; a content-only scanner removed the obvious attacks but not fact-level contradictions; the pre-index provenance gate removed all of it. **Not defensible:** that the gate prevents all poisoning or prompt injection.

11. Next Steps

(1) Run with GEMINI_API_KEY to measure answer-level attack success. (2) Add Bangla and mixed-language poisoned documents. (3) Add obfuscated injections (Unicode, invisible text, paraphrase). (4) Add a semantic contradiction check that compares new documents with existing trusted policies, targeting the misses in Section 8. (5) Report latency and repeated-run confidence intervals.

12. Reproduction

```
python3 scripts/run_extended_experiment.py
RAG_EMBEDDING_MODEL=all-MiniLM-L6-v2 python3 scripts/run_extended_experiment.py
python3 scripts/make_charts.py
python3 scripts/generate_final_report.py
```

Outputs: outputs/extended_results_<model>.md/.csv, outputs/extended_log_<model>.txt, outputs/figures/. Source: <https://github.com/takitahmid20/rag-data-poisoning>. Paper: <https://github.com/takitahmid20/rag-data-poisoning-paper>.